ROTEIRO DE ESTUDOS · WINDOWS SERVER 2025 · MÓDULO 03

Active Directory Domain Services

Estrutura lógica e física, instalação de florestas e controladores, objetos, grupos, contas de serviço, FSMO, sites, replicação e relações de confiança

Nível	Intermediário
Carga sugerida	3 semanas (24–30 h)
Pré-requisitos	Módulos 01 e 02; DC01 e DC02 instalados em Server Core com IP fixo
Relação com AZ-802	Domínio "Deploy and manage AD DS" (20–25%), o de maior peso no AZ-802

Objetivos do módulo

- Descrever os componentes lógicos (floresta, árvore, domínio, OU) e físicos (DCs, sites, sub-redes) do AD DS.
- Criar uma floresta nova e adicionar controladores de domínio, inclusive somente leitura (RODC).
- Entender níveis funcionais e as novidades do AD DS no Windows Server 2025.
- Administrar usuários, computadores, grupos e OUs pelo PowerShell, aplicando a estratégia AGDLP.
- Escolher o tipo certo de conta de serviço: gMSA ou dMSA.
- Gerenciar funções FSMO, sites, sub-redes e replicação.
- Configurar e entender relações de confiança entre domínios e florestas.

1. O que é o AD DS

O Active Directory Domain Services é o **serviço de diretório** da Microsoft: um banco de dados hierárquico e replicado que guarda contas de usuários, computadores, grupos e políticas, e o serviço que **autentica** (prova quem você é, via Kerberos ou NTLM) e ajuda a **autorizar** (o que você pode acessar) nos recursos da rede. Quase toda empresa com Windows tem um AD; por isso este é o módulo mais importante do roteiro.

1.1 Estrutura lógica

Componente	O que é
Floresta (forest)	O limite máximo de segurança e de esquema. Todos os domínios de uma floresta compartilham o mesmo esquema, a mesma configuração e o mesmo Catálogo Global.
Árvore (tree)	Domínios com namespace DNS contíguo (corp.lab.internal e filial.corp.lab.internal).
Domínio	Limite de replicação dos objetos do domínio e de algumas políticas (senha padrão). Identificado por nome DNS e NetBIOS.
Unidade Organizacional (OU)	Contêiner para organizar objetos, **delegar administração** e **vincular GPOs**. Não é um grupo de segurança.

Componente	O que é
Objetos	Usuários, computadores, grupos, contatos, impressoras, contas de serviço. Cada um tem um GUID e, se for entidade de segurança, um SID.
Esquema (schema)	Define as classes de objetos e os atributos permitidos. Alterá-lo é ação de toda a floresta.

1.2 Partições do banco (naming contexts)

O banco `NTDS.dit` é dividido em partições, cada uma com seu escopo de replicação:

- **Schema** e **Configuration**: replicadas para todos os DCs da floresta.
- **Domain**: replicada para os DCs do domínio.
- **Partições de aplicação**: por exemplo `DomainDnsZones` e `ForestDnsZones`, onde ficam as zonas DNS integradas ao AD (Módulo 05).

1.3 Estrutura física

- **Controlador de domínio (DC)**: servidor que guarda uma cópia do banco e responde a autenticações. O AD é multimaster: quase todas as alterações podem ser feitas em qualquer DC gravável.
- **Catálogo Global (GC)**: DC que guarda uma cópia parcial de todos os objetos da floresta, usada em buscas e no logon (resolve grupos universais).
- **Sites e sub-redes**: representam a topologia física da rede. O cliente procura um DC do próprio site, e a replicação entre sites é agendada e comprimida.
- **SYSVOL**: pasta compartilhada em todos os DCs com scripts de logon e os arquivos das GPOs, replicada por DFS-R.

2. Pré-requisitos e boas práticas antes de instalar

- **IP fixo** no DC e DNS apontando para um DC (no primeiro DC, para ele mesmo).
- **Nome DNS do domínio**: use um subdomínio de um domínio que você controla (ex.: `ad.suaempresa.com.br`) ou, em laboratório, um nome sob `.internal`. Evite domínios de nível único e não use `.local` em projetos novos.
- **Hora correta**: o Kerberos tolera, por padrão, no máximo 5 minutos de diferença entre cliente e DC.
- **Pelo menos dois DCs por domínio** em produção. Um DC sozinho é um ponto único de falha da empresa inteira.
- **Não coloque** o banco do AD, os logs ou o SYSVOL em volume **ReFS**: a documentação de instalação é explícita sobre isso.
- **Nível funcional**: florestas novas exigem no mínimo o nível Windows Server 2016.

3. Instalação de uma floresta nova (DC01)

O antigo `dcpromo.exe` foi descontinuado. A instalação usa o módulo **ADDSDeployment** do PowerShell, que é o mesmo motor por trás do assistente gráfico (o botão "View script" do assistente mostra o comando gerado).

```
# No DC01 (Server Core), como Administrador local
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools

# Sempre teste antes: o cmdlet Test-* roda só as verificações de pré-requisito
Test-ADDSForestInstallation -DomainName corp.lab.internal -DomainNetbiosName CORP `
    -ForestMode Win2025 -DomainMode Win2025 -InstallDns

Install-ADDSForest -DomainName corp.lab.internal -DomainNetbiosName CORP `
    -ForestMode Win2025 -DomainMode Win2025 -InstallDns `
    -DatabasePath C:\Windows\NTDS -LogPath C:\Windows\NTDS -SysvolPath C:\Windows\SYSVOL
# A senha do DSRM é pedida de forma mascarada. O servidor reinicia sozinho.
```

SEGURANÇA

A senha do **DSRM** (Directory Services Restore Mode) é a senha do administrador local de recuperação do DC. Quem a conhece pode se passar pelo próprio DC. Guarde-a em cofre de senhas e nunca a passe em texto puro em scripts, como alerta a documentação oficial.

3.1 Verificação pós-instalação

```
Get-ADDomain | Select-Object DNSRoot, NetBIOSName, DomainMode, PDCEmulator
Get-ADForest | Select-Object Name, ForestMode, SchemaMaster, GlobalCatalogs
Get-Service NTDS, DNS, Netlogon, Kdc, DFSR | Select-Object Name, Status
Get-SmbShare | Where-Object Name -in 'SYSVOL','NETLOGON'
Resolve-DnsName -Type SRV _ldap._tcp.dc._msdcs.corp.lab.internal
dcdiag /v /c /e > C:\dcdiag.txt
```

4. Controladores adicionais e RODC

4.1 Segundo DC (DC02)

```
# No DC02: IP 10.10.10.11, DNS apontando para 10.10.10.10, já ingressado no domínio
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
Install-ADDSDomainController -DomainName corp.lab.internal -InstallDns `
    -Credential (Get-Credential CORP\Administrator)
```

Depois da promoção, ajuste o DNS de cada DC: primário apontando para o **outro** DC e secundário para si mesmo (`127.0.0.1`). Isso evita que um DC fique isolado durante a inicialização.

4.2 Read-Only Domain Controller (RODC)

O RODC guarda uma cópia **somente leitura** do banco e, por padrão, **nenhuma senha**. É pensado para filiais sem segurança física. A **Password Replication Policy (PRP)** define quais senhas podem ser armazenadas nele: os grupos privilegiados ficam sempre negados (grupo *Denied RODC Password Replication Group*).

A instalação em dois estágios permite que alguém da filial, sem ser Domain Admin, conclua a promoção:

```
# Estágio 1 (no DC01): pré-criar a conta do RODC e delegar a instalação
Add-ADDSReadOnlyDomainControllerAccount -DomainControllerAccountName RODC1 `
    -DomainName corp.lab.internal -SiteName Filial-SP -DelegatedAdministratorAccountName
        ↪ tecnico.filial

# Estágio 2 (no servidor da filial, fora do domínio)
Install-ADDSDomainController -DomainName corp.lab.internal -UseExistingAccount `
    -Credential (Get-Credential CORP\tecnico.filial)
```

5. Níveis funcionais e novidades do 2025

O nível funcional define quais recursos do AD estão disponíveis e qual a versão mínima de Windows Server que pode ser DC. O Windows Server 2025 introduziu um **novo nível funcional** (valor 10 de `DomainLevel` e `ForestLevel` em instalações automáticas). A documentação informa que não haverá novos níveis retroativos para 2019 e 2022.

Principais novidades do AD DS no 2025:

- **Páginas de 32k no banco** (recurso opcional): desde o Windows 2000 o banco usava páginas de 8k, o que limitava o tamanho de um objeto. Com 32k, atributos multivalorados chegam a cerca de 3.200 valores. DCs novos já nascem com banco compatível, mas a ativação é **em toda a floresta** e exige que todos os DCs tenham banco com suporte a 32k e o nível funcional 2025.
- **Reparo de objetos** com atributos essenciais ausentes, pela operação `fixupObjectState`.
- **LDAP**: suporte a TLS 1.3; em implantações novas, assinatura e selagem do LDAP exigidas por padrão; atributos confidenciais só podem ser lidos ou alterados em conexão criptografada; auditoria de channel binding (eventos 3074 e 3075).
- **Kerberos**: o KDC não emite mais TGT com criptografia RC4; o PKINIT ganhou agilidade criptográfica; a chave de registro antiga `SupportedEncryptionTypes` deixou de ser respeitada (use GPO).
- **Senhas de computador**: contas novas recebem senha aleatória e DCs 2025 bloqueiam definir a senha padrão (igual ao nome).
- **Suporte a NUMA**: o AD passa a usar processadores de todos os grupos, indo além de 64 núcleos.
- **Prioridade de replicação** ajustável por parceiro e partição.
- Nova conta de serviço **dMSA** (seção 7).

```
Get-ADOptionalFeature -Filter * | Select-Object Name, EnabledScopes
(Get-ADForest).ForestMode
(Get-ADDomain).DomainMode
```

6. Objetos: OUs, usuários, computadores e grupos

6.1 Uma estrutura de OUs que ajuda

Organize as OUs pensando em **duas perguntas**: quem administra estes objetos (delegação) e quais políticas eles recebem (GPOs). Uma estrutura simples para o lab:

```
corp.lab.internal
├── _Admin            (contas administrativas, grupos privilegiados)
├── Usuarios
│   ├── TI
│   ├── Financeiro
│   └── RH
├── Computadores
│   ├── Estacoes
│   └── Notebooks
├── Servidores
│   ├── Arquivos
│   └── Aplicacao
├── Grupos
└── Contas-de-Servico
```

```
$base = "DC=corp,DC=lab,DC=internal"
'_Admin','Usuarios','Computadores','Servidores','Grupos','Contas-de-Servico' | ForEach-Object {
    New-ADOrganizationalUnit -Name $_ -Path $base -ProtectedFromAccidentalDeletion $true
}
'TI','Financeiro','RH' | ForEach-Object { New-ADOrganizationalUnit -Name $_ -Path
    ↪ "OU=Usuarios,$base" }

# Novos computadores entram direto na OU certa, e não no contêiner padrão "Computers"
redircmp "OU=Estacoes,OU=Computadores,$base"
```

6.2 Usuários

```
$senha = Read-Host "Senha inicial" -AsSecureString
New-ADUser -Name "Ana Souza" -GivenName Ana -Surname Souza -SamAccountName ana.souza `
    -UserPrincipalName ana.souza@corp.lab.internal -Department Financeiro `
    -Path "OU=Financeiro,OU=Usuarios,$base" -AccountPassword $senha `
    -ChangePasswordAtLogon $true -Enabled $true

# Criação em massa a partir de CSV (colunas: Nome,Sobrenome,Login,Depto)
Import-Csv .\usuarios.csv | ForEach-Object {
    New-ADUser -Name "$($_.Nome) $($_.Sobrenome)" -SamAccountName $_.Login `
      -UserPrincipalName "$($_.Login)@corp.lab.internal" -Department $_.Depto `
      -Path "OU=$($_.Depto),OU=Usuarios,$base" -AccountPassword $senha -Enabled $true `
      -ChangePasswordAtLogon $true
}

# Tarefas do dia a dia (muito comuns em suporte)
Unlock-ADAccount ana.souza
Set-ADAccountPassword ana.souza -Reset -NewPassword (Read-Host -AsSecureString)
Get-ADUser ana.souza -Properties LockedOut, LastLogonDate, PasswordLastSet, MemberOf
Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 -UsersOnly
Search-ADAccount -LockedOut
```

6.3 Grupos: tipos, escopos e AGDLP

Escopo	Pode conter	Pode receber permissão em	Uso típico
Global	Contas e grupos globais do **mesmo domínio**	Qualquer domínio da floresta (e confiáveis)	Agrupar **pessoas** por função: GG-Financeiro
Domain Local	Contas, globais e universais de qualquer domínio confiável; outros domain local do mesmo domínio	Só no próprio domínio	Representar **permissões** em um recurso: DL-Pasta-Financeiro-Leitura
Universal	Contas, globais e universais de qualquer domínio da floresta	Qualquer domínio da floresta	Florestas com vários domínios; replicado no Catálogo Global

Os grupos ainda podem ser de **Segurança** (recebem permissões) ou de **Distribuição** (só listas de e-mail).

A estratégia recomendada é **AGDLP**: **A**ccounts entram em **G**lobal groups, que entram em **D**omain **L**ocal groups, que recebem **P**ermissions. Em florestas com vários domínios, use AGUDLP (com um grupo Universal no meio). O ganho: quando alguém muda de setor, você mexe em um grupo, não em dezenas de ACLs.

```
New-ADGroup -Name GG-Financeiro -GroupScope Global -GroupCategory Security -Path "OU=Grupos,$base"
New-ADGroup -Name DL-Pasta-Financeiro-RW -GroupScope DomainLocal -GroupCategory Security -Path
    ↪ "OU=Grupos,$base"
Add-ADGroupMember GG-Financeiro -Members ana.souza
Add-ADGroupMember DL-Pasta-Financeiro-RW -Members GG-Financeiro
Get-ADGroupMember DL-Pasta-Financeiro-RW -Recursive
```

> **NOTA**
>
> A pertença a grupos entra no **token de acesso** no momento do logon (ou da obtenção do ticket Kerberos). Depois de adicionar alguém a um grupo, o usuário precisa fazer logoff e logon (ou `klist purge`) para a mudança valer.

6.4 Delegação de controle

Em vez de dar *Domain Admins* ao suporte, delegue permissões específicas numa OU, por exemplo "redefinir senha e desbloquear contas" em `OU=Usuarios`. Use o assistente **Delegate Control** no ADUC ou o comando `dsacls`. Documente toda delegação: ela é invisível para quem só olha os membros dos grupos.

7. Contas de serviço

Serviços e tarefas agendadas precisam de uma identidade. Usar uma conta de usuário comum com senha que nunca expira é um dos riscos mais explorados em ataques ao AD (Kerberoasting). As alternativas gerenciadas:

Tipo	Senha	Onde pode ser usado	Observação
Conta virtual / LocalService / NetworkService	Gerenciada pelo Windows	Só no servidor local	Para serviços que não precisam de identidade de rede própria
gMSA (Group Managed Service Account)	240 caracteres, trocada automaticamente pelo AD	Em vários servidores autorizados	Padrão recomendado para serviços, pools do IIS, tarefas agendadas
dMSA (Delegated MSA), novo no 2025	Chaves gerenciadas e totalmente aleatórias	Migração de contas de serviço tradicionais	Permite migrar um serviço que usa conta comum, desabilitando a senha antiga com mínimo de alteração na aplicação

7.1 gMSA na prática

```
# 1) Uma vez por floresta: chave raiz do KDS (em produção, aguarde a replicação; ~10 h)
Add-KdsRootKey -EffectiveImmediately
# Só em laboratório com um DC, para não esperar:
# Add-KdsRootKey -EffectiveTime ((Get-Date).AddHours(-10))

# 2) Grupo de servidores autorizados a ler a senha
New-ADGroup -Name GG-Servidores-App -GroupScope Global -Path "OU=Grupos,$base"
Add-ADGroupMember GG-Servidores-App -Members (Get-ADComputer SRV01)

# 3) Criar a gMSA
New-ADServiceAccount -Name gmsa-app01 -DNSHostName gmsa-app01.corp.lab.internal `
    -PrincipalsAllowedToRetrieveManagedPassword GG-Servidores-App -Path
        ↪ "OU=Contas-de-Servico,$base"

# 4) No SRV01 (após reiniciar ou klist purge para pegar o novo grupo)
Install-ADServiceAccount gmsa-app01
Test-ADServiceAccount gmsa-app01      # deve retornar True
# Ao configurar o serviço, use CORP\gmsa-app01$ e deixe a senha em branco
```

SEGURANÇA

dMSA exige atenção: em 2025 a Microsoft corrigiu uma vulnerabilidade de elevação de privilégio envolvendo contas dMSA (CVE-2025-53779). Mantenha os DCs atualizados e restrinja quem pode criar objetos dMSA nas OUs. Leia a página oficial de dMSA antes de usar em produção.

8. Funções FSMO

Algumas operações não podem ser multimaster. Elas ficam com um único DC, o dono da função FSMO (Flexible Single Master Operations).

Função	Escopo	O que faz	Se ficar fora do ar
Schema Master	Floresta	Única que aceita alterações no esquema	Só impede alterações de esquema (ex.: preparar upgrade)
Domain Naming Master	Floresta	Adiciona e remove domínios e partições	Não dá para criar domínios novos
RID Master	Domínio	Entrega blocos de RIDs aos DCs para criar SIDs	DCs param de criar objetos quando acabar o bloco
PDC Emulator	Domínio	Fonte de hora do domínio, mudanças de senha urgentes, bloqueios de conta, edição de GPO por padrão	Impacto rápido e visível: hora, senhas e logons
Infrastructure Master	Domínio	Atualiza referências a objetos de outros domínios	Pouco impacto se todos os DCs forem GC

```
netdom query fsmo
Get-ADDomain | Select-Object PDCEmulator, RIDMaster, InfrastructureMaster
Get-ADForest | Select-Object SchemaMaster, DomainNamingMaster

# Transferência planejada (DC de origem online)
Move-ADDirectoryServerOperationMasterRole -Identity DC02 -OperationMasterRole PDCEmulator,
    ↪ RIDMaster

# Tomada forçada (seize): só se o dono original morreu e NUNCA mais voltará à rede
Move-ADDirectoryServerOperationMasterRole -Identity DC02 -OperationMasterRole SchemaMaster -Force
```

9. Sites, sub-redes e replicação

- **Replicação intrassite**: quase imediata (notificação após alterações), sem compressão. Topologia em anel gerada pelo **KCC** (Knowledge Consistency Checker).
- **Replicação intersite**: segue o **site link** (custo, agenda e intervalo, padrão de 180 minutos), com compressão. Em cada site, um DC atua como **ISTG** e calcula as conexões entre sites.
- **Urgente**: bloqueios de conta e algumas mudanças de segurança são replicadas imediatamente.

```
New-ADReplicationSite -Name Filial-RJ
New-ADReplicationSubnet -Name 10.20.0.0/24 -Site Filial-RJ
New-ADReplicationSubnet -Name 10.10.10.0/24 -Site Default-First-Site-Name
New-ADReplicationSiteLink -Name "SP-RJ" -SitesIncluded Default-First-Site-Name, Filial-RJ `
    -Cost 100 -ReplicationFrequencyInMinutes 60

repadmin /replsummary            # resumo de falhas por DC
repadmin /showrepl DC02          # parceiros e último sucesso
repadmin /syncall /AdeP          # forçar replicação de todas as partições
Get-ADReplicationFailure -Target DC01
```

DICA

Um cliente sem sub-rede cadastrada não sabe em que site está e pode autenticar num DC do outro lado do país. Sempre cadastre todas as sub-redes, inclusive as de VPN.

10. Relações de confiança

Uma confiança permite que usuários de um domínio acessem recursos de outro. O domínio que **confia** (trusting) é o dos recursos; o domínio **confiado** (trusted) é o das contas.

Tipo	Transitiva?	Quando aparece
Pai-filho e raiz de árvore	Sim, bidirecional	Automática dentro da floresta
Floresta (forest trust)	Sim, entre as duas florestas	Fusões e aquisições, florestas de recursos
Externa	Não	Com um domínio específico de outra floresta ou domínio legado
Atalho (shortcut)	Sim	Encurtar o caminho de autenticação em florestas grandes
Realm	Configurável	Com reinos Kerberos não Windows (MIT/Linux)

Controles de segurança das confianças:

- **SID filtering**: descarta SIDs de outro domínio no histórico do token, evitando elevação de privilégio via `sIDHistory`. Ativo por padrão em confianças externas e de floresta.
- **Autenticação seletiva**: os usuários do outro lado só acessam servidores em que você der explicitamente a permissão "Allowed to authenticate".

```
Get-ADTrust -Filter *
netdom trust corp.lab.internal /domain:parceiro.internal /verify
```

LABORATÓRIO

Laboratório 3.1: o domínio do laboratório

- Promova DC01 (nova floresta) e DC02 (DC adicional). Ajuste o DNS dos dois em cruz.
- Crie a estrutura de OUs da seção 6.1 e 20 usuários a partir de um CSV.
- Implemente AGDLP para uma pasta do Financeiro (a pasta será criada no Módulo 06).
- Crie uma gMSA e use-a como identidade de uma tarefa agendada no SRV01 (`Register-ScheduledTask` com `-Principal` usando `-LogonType Password` e o nome `CORP\gmsa-app01$`).
- Ingresse o CLI01 no domínio e verifique em qual OU ele caiu.
- Transfira o PDC Emulator para o DC02 e depois devolva ao DC01. Observe `netdom query fsmo`.
- Crie o site "Filial-RJ" com sua sub-rede e um site link. Rode `repadmin /replsummary`.

LABORATÓRIO

Laboratório 3.2: delegação para o suporte

- Crie o grupo `GG-Suporte-N1` e um usuário de suporte.
- Delegue na OU `Usuarios` apenas: redefinir senha, forçar troca no próximo logon e desbloquear conta.
- Teste com o usuário de suporte: ele deve conseguir redefinir a senha da Ana, mas não criar usuários nem mexer em grupos.

Checklist de revisão

- Qual o limite de segurança do AD: domínio ou floresta? Por quê?
- O que fica em cada partição do banco e para onde cada uma é replicada?
- Quais as 5 funções FSMO, seu escopo e o impacto de cada uma ficar indisponível?
- Explique AGDLP com um exemplo de pasta compartilhada.
- Quando usar gMSA e quando considerar dMSA?
- O que é a PRP de um RODC? Quais contas nunca devem ter senha armazenada nele?
- Por que cadastrar todas as sub-redes nos sites?
- O que são SID filtering e autenticação seletiva?
- Cite três mudanças de segurança do AD DS no Windows Server 2025.

Referências oficiais

› Instalar o Active Directory Domain Services (PowerShell e Server Manager)
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/deploy/install-active-directory-domain-services--level-100-

› Referência do módulo ADDSDeployment
https://learn.microsoft.com/en-us/powershell/module/addsdeployment

› Níveis funcionais do AD DS
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/active-directory-functional-levels

› Novidades do Windows Server 2025 (seção AD DS)
https://learn.microsoft.com/en-us/windows-server/get-started/whats-new-windows-server-2025

› Visão geral das contas dMSA
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/delegated-managed-service-accounts/delegated-managed-service-accounts-overview

› Visão geral das contas gMSA
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/group-managed-service-accounts/group-managed-service-accounts/group-managed-service-accounts-overview

› Localização de controladores de domínio (DC Locator)
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/dc-locator

› Assinatura LDAP no AD DS
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing

› MSRC: CVE-2025-53779 (elevação de privilégio no Kerberos)
https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-53779

› Grupos de segurança do Active Directory
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-security-groups